

# Compliance-Driven Identity and Access Management (IAM) in Critical Infrastructure

Srikanth Mandru  
Information Security Engineer  
Cisco Systems  
USA  
mandrusrikanth9@gmail.com

Anvesh Gunuganti  
Principal Information security Engineer  
Change health care  
USA  
anvesh.gunuganti@gmail.com

**Abstract—** Compliance demands have emerged as the main drivers for the investments in cybersecurity especially in critical sectors as most of these systems require protection in order to maintain national security and economic stability. To achieve this, IAM systems can be used to control and oversee the access to systems and data. This paper analyses how international compliance standards that include but not limited to NIST, GDPR, HIPAA, and others influence IAM approaches for critical infrastructure. We discuss the challenges that organizations experience in balancing compliance policies and security objectives and also look at new trends that stand to shape IAM in the future such as Zero Trust Architecture and use of AI in IAM. This research gives insights and a conceptual framework that can help implement IAM in heavily regulated industries.

**Keywords—** Compliance, Identity and Access Management (IAM), Critical Infrastructure (CI), Patient Health Information (PHI), Cybersecurity, NIST, GDPR, Regulatory Standards, Zero Trust, Artificial Intelligence (AI)

## I. INTRODUCTION

Critical infrastructure sectors such as energy, healthcare, finance, transport and utilities are some of the sectors that today's societies cannot do without. As these sectors dependence on interconnected digital systems increases, ensuring their cybersecurity becomes important and therefore has to be prioritized. Cyber-attacks on critical infrastructure are potentially devastating for a country and its economy, and in some cases represent threats to national security and public safety. These attacks can be minimized by having strong IAM methods in place [1].

Regulations like National Institute of Standards and Technology (NIST), the General Data Protection Regulation (GDPR), and Health Insurance Portability and Accountability Act (HIPAA) have strict obligations on organizations in terms of Identity and Access management. Compliance is a legal requirement as well as a key element in the organizational security policies.

This paper looks at the contribution of compliance requirements to IAM strategies in critical infrastructure sectors. We examine the impact of global standards such as the NIST, GDPR, HIPAA and the North American Electric Reliability Corporation's Critical Infrastructure Protection (NERC CIP). Also, we highlight issues arising from the need to meet compliance requirements and the organization's security requirements, as well as the future trends of IAM systems, including the Zero Trust Architecture and AI

## II. REGULATORY FRAMEWORKS AND THEIR IMPACT ON IAM

IAM systems can only operate under the guidelines that the different governing authorities put in place. Regulations provide the best practices to follow in order to address security of systems and information. Below we discuss some of the most notable compliance models and how they are affecting IAM in Critical Infrastructure.

**A. (NIST) National Institute of Standards and Technology:** The National Institute of Standards and Technology (NIST) has emerged as a major basis to regulation of cybersecurity with focus on critical infrastructure industries including energy, defence and finance [4].

NIST SP 800-53: Security and Privacy Controls: NIST SP 800-53 specifies controls related to identity and access management, including:

- **Access Control (AC):** Policies such as MFA and role-based access [11].
- **Audit and Accountability (AU):** Monitoring and review of access logs [11].
- **Identification and Authentication (IA):** Organizations must critically design their systems uniquely authenticate and identify users before access is granted to them [11].

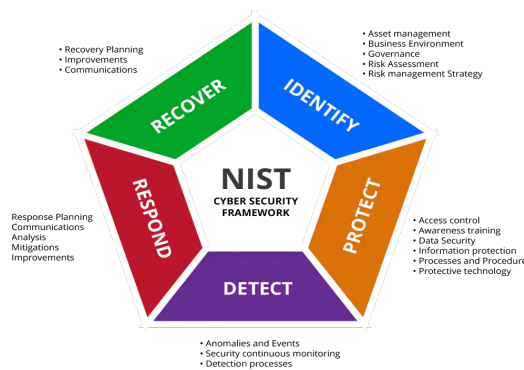


Fig 1. NIST framework

If implemented in accordance with NIST, IAM systems that protect valuable assets while at the same time addressing legal requirements can be designed and. Non-compliance is likely to attract legal and financial repercussions especially for sectors like defense, which are usually under heavy regulation.

**B. GDPR (General Data Protection Regulation):** One of the most far reaching data protection regulation is the General Data Protection Regulation (GDPR), which was implemented in 2018 [3].

Under GDPR, IAM remains very central in enforcing the access control of the Personal Data. Key IAM-related GDPR requirements include:

- **Data Access Controls:** Personal data must be restricted to only several entities within an organization or other parties that might need it while undertaking their responsibilities and duties. This means that IAM systems have to include more accurate access control models, like attribute-based access control (ABAC).
- **Audit and Transparency:** GDPR requires that all institutions maintain a record of data processing activities that involve the processing of personal data. IAM systems are required to come up with enhanced audit trails and offer transparency of access activities.
- **Data Minimization and Purpose Limitation:** IAM systems should only allow users to have the authorization level that they need to perform their specific task.

Failure to abide by the GDPR guidelines can attract heavy penalties — up to €20 million or 4% of an organization's annual global turnover. Thus, the choosing of IAM systems that provide tools to enforce compliance, improve the levels of audit and logging, as well as assist with adequate and timely revocation of privileges has to be done carefully by organizations.

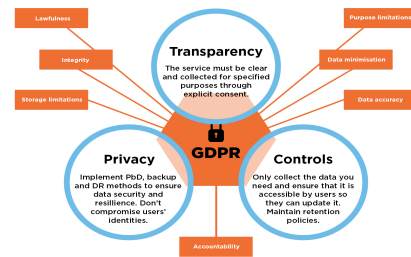


Fig 2. GDPR Framework

**C. HIPAA (Health Insurance Portability and Accountability Act):** HIPAA governs healthcare data protection. IAM systems enforce unique IDs, access controls, and automatic logoffs to safeguard PHI. Compliance-driven IAM ensures traceability and accountability across healthcare applications [2].

Key IAM requirements under HIPAA include:

- **Access Controls:** HIPAA requires that technical policies be used to control access to PHI. This includes Role Base Access Control (RBAC), where access rights granted to health care providers, administrative staff and third party requestors are granted according to the required level of access.
  - **Unique User Identification:** Any user that interacts with systems containing PHI has to have a unique id that will help track their activities.
  - **Automatic Logoff:** IAM systems have to close sessions after certain time of inactivity to reduce possibility of intrusion.
- HIPAA mandates IAM solutions for healthcare organizations that provide secure, auditable, and differentiated access to PHI.

**D. NERC CIP (Critical Infrastructure Protection Standards):** In the energy sector, North American Electric Reliability Corporation (NERC) has provided Critical Infrastructure Protection (CIP) for the security of electrical grid from cyber risks [8]. NERC CIP standards impose strict IAM requirements, including:

- **Authentication and Access Control:** Organizations are required to identify and institute ways of authenticating and authorizing the access to cyber assets. These include MFA and the ability to cancel access at any time of a breach or if there are changes to employees [1, 8].
- **Personnel Training and Risk Management:** While adopting NERC CIP, the personnel of the organizations have to be trained on IAM practices and compliance has to be checked continually [8].

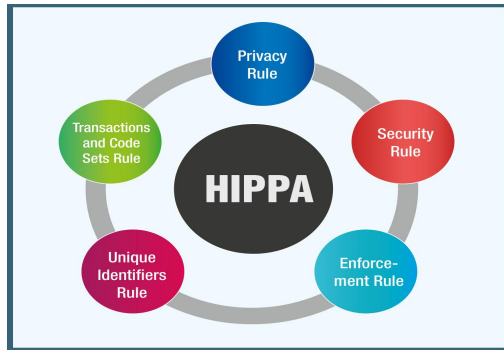


Fig 3. HIPAA Framework

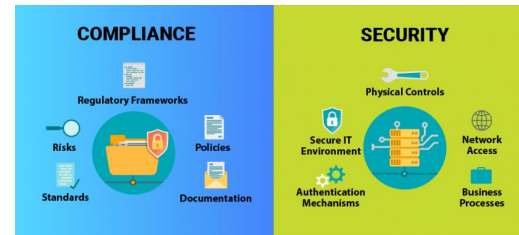
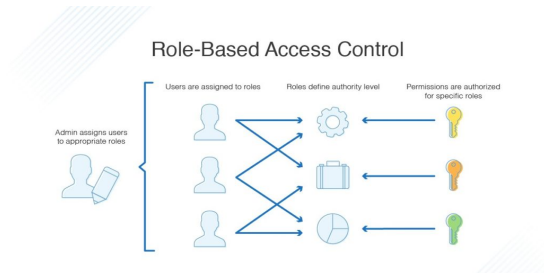


Fig 4. Security vs Compliance

**B. Access Control Models:** There are various models of IAM on access control that imply restrictive approach based on the principle of least



### III. COMPLIANCE-DRIVEN IAM: CHALLENGES AND BEST PRACTICES

Organizations in critical infrastructure sectors face a complex challenge: they have to be complaint with strict regulations as well as maintain security and safety of their systems. The following sections analyse several significant problems of compliance-driven IAM implementation and present typical solutions to these issues [9].

**A. Security Vs Compliance:** Many frameworks set minimum standards that may not fully address emerging threats. Organizations must go beyond compliance and adopt a **risk-based IAM** strategy to strengthen defense against sophisticated attacks [2].

- **Compliance as a Security Baseline:** Compliance regulations should be seen as the minimum level of security instead of the goal to be achieved. For instance, although NIST has brought in multi-factor authentication (MFA), the organization might require further enhanced authentication – such as biometric authentication if the level of risk is high.

- **Customization of IAM Solutions:** Many critical infrastructure organizations operate with old and outdated legacy systems, modern applications and cloud-based platforms collectively.

privilege that gives a user only the rights he or she needs for perform their work. Common access control models include:

- **Role-Based Access Control (RBAC):** RBAC assigns the access rights to an individual in accordance with their pre-designated role. It Simplifies administration but lacks flexibility in dynamic environments [5].

- **Attribute-Based Access Control (ABAC):** ABAC Enables fine-grained control based on user attributes and context [5].

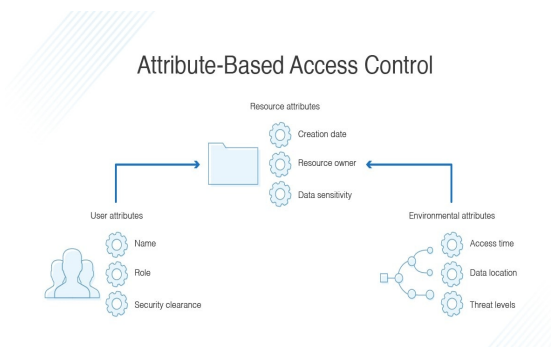
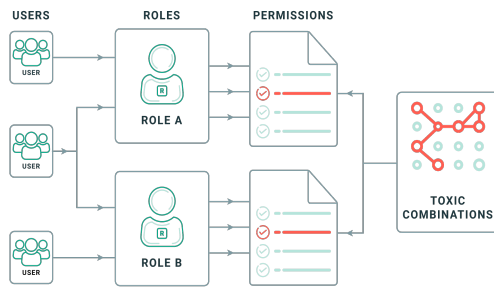


Fig 6. ABAC model

- **Policy-Based Access Control (PBAC):** PBAC separates and controls access according to a number of policies that are always evolving. It is useful in setting and applying access control in environments where the demands are ever changing [10]



Organizations need to decide on which access control model better suits their compliance and security requirements.

**C. Continuous Monitoring and Auditing:** Compliance frameworks like NIST, GDPR, and HIPAA all have put into consideration monitoring and auditing as continuous processes. The IAM systems must offer organizations a precise, real-time visibility into access activities so that any specific security breach can be noticed and dealt with promptly.

- **Automated Monitoring Tools:** Manual checking of the user access activities can be very cumbersome and can also have errors. Tools that apply IAM methods in automated fashion and connect to Security Information and Event Management (SIEM) systems allow organizations to constantly observe access actions and search for suspicious activity in real time. These tools are capable of discovering a set pattern or behaviour that a user undertakes that deviates from the norm for example, the user interacting with systems that he or she normally does not use due to an insider threat or due to compromised login credentials.

- **Regular Access Audits:** In addition to continuous monitoring, organizations need to carry out periodical access audits in order to check how they meet regulatory standards and requirements. Access audits are conducted by ensuring that the organization is only giving employees the access required to perform their functions in the organization. These audits also offer an understanding of other issues like the 'orphan accounts', for instance accounts belonging to employees that are no longer working for the organization and could be a security threat if unused accounts are granted access.

**D. Integration with Legacy Systems:** Most critical infrastructure organizations are using outdated systems and frameworks that were not built with cybersecurity considerations in mind. Adapting IAM solutions with these systems is still a challenge as it may require connecting with older systems that

sometimes do not possess the APIs or interfaces to interact with IAM systems.

- **Legacy Modernization Strategies:** There are approaches that organizations need to take into consideration to integrate legacy systems into their IAM frameworks. It may entail mid-tier implementation of middleware solutions that help translate interactions of old systems with new IAM platforms or undertake modernization efforts to domicile IAM into new systems.

## IV. THEORETICAL FRAMEWORK: THE COMPLIANCE-SECURITY CONTINUUM

**A. Compliance as a Baseline for Security:** The relative position of compliance and security can be best depicted in the form of a spectrum. On one side of the spectrum there is compliance which only defines the lowest levels of security that have to be met by law or regulation.

- **Framework Overview:** Compliance-driven IAM puts emphasis on legal requirements while security IAM demands that organizations understand the risk profiles of their organizations and put into practice matters of security control.

**B. Risk-Based Approach to IAM:** Risk based IAM enables the organizations to apply particular access controls on the basis of the risks faced while protecting the systems and data. For instance, systems that are dealing with classified national security information should require high level of security than say a system, which is managing ordinary data.

## V. CASE STUDY: IAM IN THE ENERGY SECTOR

Energy sector is one of the critical infrastructure sector that is closely regulated, especially in United States where the organizations must follow the NERC CIP standards and NIST regulations.

**A. IAM Requirements under NERC CIP:** IAM systems of energy companies must support:

- **Multi-Factor Authentication (MFA):** The implementation of NERC CIP involves requiring MFA for anybody who is allowed to access the important cyber assets[8].

- **Continuous Monitoring:** Managing users' access means that firms must monitor user access constantly and have audit trails so that they may determine who accessed crucial systems and when [8].

- **Access Revocation:** Any time an employee is transferred or resigns or is dismissed from the company, then their access to such systems needs to be terminated [8].

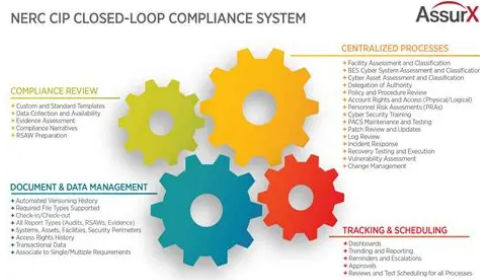


Fig 8. NERC compliance system

**B. Risk-Based IAM Implementation:** Organizations that adopt risk based IAM strategies can those strategies to apply access control to the systems that are most vital to energy companies. For example, there are systems which control grid operations and they may allow an access level that is much lower than those used in administrative applications which are non-critical [12].

The reason for integration of IAM into the overall strategy of energy sector cybersecurity is that the having more formal and comprehensive compliance checking and security controls minimizes internal threat as well as external threats exposure [7].

## VI. FUTURE TRENDS IN COMPLIANCE-DRIVEN IAM

**A. Zero Trust Architecture:** Zero Trust eliminates implicit trust and enforces continuous authentication based on context. IAM serves as the foundation of ZTA by validating identity, device, and behavioral attributes for every request. [6].

- **IAM in Zero Trust:** Zero Trust architecture fundamentally transforms the IAM approach in sectors of significance. In contrast to the notion of using a perimeter to protect, IAM in the Zero Trust environment is always checking the approval status of each user access request and its context, that is, the user's identification, device health and geographical location [6].

**B. Artificial Intelligence and Machine Learning in IAM:** AI-driven IAM systems enable adaptive authentication and predictive threat detection. ML models identify anomalies and support automated compliance auditing, enhancing resilience against modern threats.

Other areas ML can help with are access auditing where it can be used to scan through many logs to try and find a pattern that might suggest a break in. This can greatly enhance compliance efforts by ensuring that organizations remain vigilant about user access.

## VII. CONCLUSION

Compliance-driven IAM protects critical infrastructure but must evolve beyond regulatory checklists. Compliance should be viewed as the foundation, not the ceiling, of security. A risk-based, adaptive IAM framework - integrating Zero Trust and AI - enables organizations to meet regulatory expectations while proactively defending against emerging cyber threats. The future of IAM in critical sectors lies in aligning compliance with continuous, intelligence-driven security [14-20].

The evolution of compliance-driven IAM will continue to be dictated by evolving regulatory requirements, the Zero Trust model and the integration of a variety of digital IAM processes and AI technology. As the threats continues to grow, organizations need to remain prepared and flexible enough to enable the IAM systems to defend against the current and future advance threats [13].

## REFERENCES

- [1] NordLayer, "IAM Compliance: Achieving Goals and Regulations | NordLayer Learn," NordLayer. <https://nordlayer.com/learn/iam/compliance/>
- [2] O. for C. Rights, "Summary of the HIPAA Privacy Rule," HHS.gov, Oct. 19, 2022. <https://www.hhs.gov/hipaa/for-professionals/privacy/laws-regulations/index.html>
- [3] G. Helemski, "6 Regulations Requiring IAM Compliance," PlainID, Apr. 20, 2020. <https://blog.plainid.com/6-regulations-requiring-iam-compliance>
- [4] "Understanding the NIST cybersecurity framework," Federal Trade Commission, Oct. 06, 2022. <https://www.ftc.gov/business-guidance/small-businesses/cybersecurity/nist-framework>
- [5] "RBAC vs. ABAC: Definitions & When to Use | Okta," Okta, Inc. <https://www.okta.com/identity-101/role-based-access-control-vs-attribute-based-access-control/>
- [6] "What is IAM Zero Trust Framework?," SSH, Dec. 28, 2022. <https://www.ssh.com/academy/iam/zero-trust-framework>
- [7] U.S. Department of Energy, "Energy Sector Cybersecurity Framework Implementation Guidance," report, 2015. [https://www.energy.gov/sites/prod/files/2015/01/f19/Energy%20Sector%20Cybersecurity%20Framework%20Implementation%20Guidance\\_FINAL\\_01-05-15.pdf](https://www.energy.gov/sites/prod/files/2015/01/f19/Energy%20Sector%20Cybersecurity%20Framework%20Implementation%20Guidance_FINAL_01-05-15.pdf)
- [8] R. Awati and B. Cole, "North American Electric Reliability Corporation Critical Infrastructure Protection (NERC CIP)," Security, Mar. 02, 2022. <https://www.techtarget.com/searchsecurity/definition/North-American-Electric-Reliability-Corporation-Critical-Infrastructure-Protection-NERC-CIP>
- [9] "IAM: the cornerstone of a successful cybersecurity strategy," Ilex International, Sep. 22, 2022. <https://www.illex-international.com/en/iam-strategy/security>
- [10] Computer Security Division, Information Technology Laboratory, National Institute of Standards and Technology, U.S. Department of Commerce, "Access Control Policy and Implementation Guides | CSRC | CSRC." <https://csrc.nist.gov/Projects/Access-Control-Policy-and-Implementation-Guides>



[11] "Security and privacy controls for information systems and organizations," Sep. 2020.  
<https://doi.org/10.6028/NIST.SP.800-53r5>

[12] Bhandari R.S. and Sharma H.(2017) "Impact of Social media on Brand Loyalty: Study of Buying Behaviour" *International Journal of Applied Business and Economic Research* 15 (1), 297-308

[13] Bhandari R.S., Bansal S. and Bansal A. (2021) "Attitude towards the usage of internet-based applications in management education: Study of the Indian Scenario" *Journal of Cases on Information Technology* 23(4), pp. 1–15

[14] Sharma A., Sharma R.K., Nanda S. & Misra A., 2022. Emerging real time analytics based health start-ups: opportunities during covid-19, *Journal of Medical Pharmaceutical and Allied Science* 11 (4), pp. 5017 – 5025,

[15] Bhandari, R. S. (2023). Use of social networking sites for B school marketing: an empirical analysis. *International Journal of Business and Globalisation*, 33(3), 344-361.

[16] Kumar, V., Panwar, S., Kapur, P. K., & Singh, O. (2021). Optimal decisions on software release and post-release testing: a unified approach. *YUJOR*, 31(2), 165-180.

[17] Singh, G., Bhardwaj, G., Singh, S. V., Chaturvedi, P., Kumar, V., & Gupta, S. (2021, November). Industry 4.0: the industrial revolution and future landscape in Indian Market. In *2021 international conference on technological advancements and innovations (ICTAI)* (pp. 500-505). IEEE.

[18] H. A. Rehman, N. Sahay, A. Srivastava, S. Nanda, N. Pancholi and G. S. Siddhu, "Risk Management in Cryptocurrencies: A Portfolio Perspective," 2025 International Conference on Engineering, Technology & Management (ICETM), Oakdale, NY, USA, 2025, pp. 1-6.

[19] Gupta, S., Bhandari, R. S., Aggarwal, A., & Gupta, S. (2025). Reactions towards online advertisements for millennials: a fuzzy AHP approach. *International Journal of System Assurance Engineering and Management*, 1-13.

[20] Ramdinpuui, O., Chaudhary, K., Kapur, P. K., Dhakal, K. N., Bhatia, S. K., & Kumar, V. (2024). Modelling the impact of advertising and quality on goodwill under dynamic conditions. *International Journal of System Assurance Engineering and Management*, 1-10.